Security Audit Report

Authorized password-strength assessment & storage-security analysis

AUTHORIZED USE ONLY. This report was produced by an authorized password security assessment against SYNTHETIC test data. It must not be used to access accounts without explicit permission. No real user secrets are collected or stored.

Audit Overview

Dataset	Web app SHA-256 (unsalted)
Attack type	all
Started	2026-11-02T13:15:32+00:00
Finished	2026-11-02T13:15:32+00:00
Duration (s)	0.436
Accounts audited	17
Algorithms	sha256

Results Summary

Passwords recovered: 14 / 17 (82.4%)

Overall risk: Critical Storage grade: Poor

Total candidate attempts: 17

Risk breakdown - Critical: 8 High: 6 Medium: 0 Low: 3

Password Storage Assessment

- Passwords are stored as fast, unsalted hashes -- vulnerable to dictionary, hybrid and rainbow-table attacks. Migrate to a salted, slow KDF (PBKDF2, scrypt, bcrypt or Argon2).

Per-Account Findings

Username	Algo	Cracked	Method	Risk	Recovered
alice	sha256	Yes	dictionary	Critical	password
bob	sha256	Yes	dictionary	Critical	123456
carol	sha256	Yes	dictionary	Critical	qwerty
dave	sha256	Yes	dictionary	Critical	letmein
erin	sha256	Yes	dictionary	Critical	dragon
frank	sha256	Yes	dictionary	Critical	monkey
grace	sha256	Yes	dictionary	Critical	iloveyou
heidi	sha256	Yes	dictionary	Critical	sunshine
ivan	sha256	Yes	hybrid	High	Summer2021
judy	sha256	Yes	hybrid	High	welcome1
mallory	sha256	Yes	hybrid	High	dragon!
niaj	sha256	Yes	hybrid	High	Monkey99
olivia	sha256	Yes	hybrid	High	p@$$w0rd
peggy	sha256	Yes	hybrid	High	Qwerty123
rupert	sha256	No	-	Low	-
sybil	sha256	No	-	Low	-
trent	sha256	No	-	Low	-

Recommendations

- 14 of 17 passwords were recovered (82.4%). Force resets for all affected accounts.
- Re-hash all stored passwords with a salted, slow KDF (PBKDF2 >= 200k iters, scrypt, bcrypt, or Argon2id).
- Enforce a minimum length of 12+ characters and screen new passwords against a common-password blocklist.
- Enable multi-factor authentication to reduce the impact of any single compromised password.

Method Limitations

- Dictionary: only finds passwords present in the wordlist.
- Hybrid: only rule-expressible mutations; candidate space grows fast.
- Rainbow/lookup: storage grows with coverage and is defeated by salting; this tool uses a direct hash-lookup table, not reduction-chain rainbow tables.
- Results are bounded by the chosen wordlist and single-machine Python speed; a dedicated GPU cracker would be faster.